

Security Scan Report

Target: <https://juice-shop.herokuapp.com/#/>

Scan Date: May 08, 2026 at 03:07 UTC

Scan ID: dd1453f5-518a-4eb5-a7ec-156444c4faa1

0 CRITICAL

1 HIGH

6 MEDIUM

9 LOW

Executive Summary

Security scan of 'https://juice-shop.herokuapp.com/#!/' identified 18 raw findings, reduced to 16 unique issues after deduplication. ■ 1 HIGH-severity issue(s) should be prioritized for remediation within the next 48 hours. 6 MEDIUM-priority issue(s) should be addressed in the current development sprint. 9 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	18
After Deduplication	16
Critical Findings	0
High Findings	1
Medium Findings	6
Low Findings	9
Scan Duration	91.6s

Detailed Findings

[HIGH] #1: Missing Auth in admin:0

Risk Score	0.6839
Affected Location	https://juice-shop.herokuapp.com/admin:0
Vulnerability Type	MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation
Missing or broken authentication allows unauthorized users to access protected functionality or data without proper identity verification.

Code or HTTP Excerpt

```
1 | GET /admin → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact
Unauthorized users could access sensitive data or perform privileged operations without any authentication.

Fix Recommendation
Rule-based recommendation: Ensure all sensitive endpoints require authentication. Use established authentication frameworks and middleware. Implement proper session management with secure cookie flags.

LLM recommendation: Ensure all sensitive endpoints require authentication. Use established authentication frameworks and middleware. Implement proper session management with secure cookie flags.

[MEDIUM] #2: Information Disclosure in .env:0

Risk Score	0.5335
Affected Location	https://juice-shop.herokuapp.com/.env:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /.env → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #3: Cors Misconfiguration in crossdomain.xml:0

Risk Score	0.4850
Affected Location	https://juice-shop.herokuapp.com/crossdomain.xml:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The server's Cross-Origin Resource Sharing (CORS) policy is overly permissive, potentially allowing unauthorized websites to make requests and read responses on behalf of users.

Code or HTTP Excerpt

```
1 | GET /crossdomain.xml → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

A malicious website could make authenticated API requests on behalf of your users and read the responses, potentially accessing sensitive data.

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

LLM recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

[MEDIUM] #4: Information Disclosure in config:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/.git/config:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /.git/config → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #5: Information Disclosure in backup.sql:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/backup.sql:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-530
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /backup.sql → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #6: Information Disclosure in :0

Risk Score	0.4220
Affected Location	https://juice-shop.herokuapp.com/wp-admin/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /wp-admin/ → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #7: Cors Misconfiguration in :0

Risk Score	0.3588
Affected Location	https://juice-shop.herokuapp.com/#:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The server's Cross-Origin Resource Sharing (CORS) policy is overly permissive, potentially allowing unauthorized websites to make requests and read responses on behalf of users.

Code or HTTP Excerpt

```
1 | Access-Control-Allow-Origin: *
```

Business Impact

A malicious website could make authenticated API requests on behalf of your users and read the responses, potentially accessing sensitive data.

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

LLM recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

[LOW] #8: Information Disclosure in phpinfo.php:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/phpinfo.php:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /phpinfo.php → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #9: Information Disclosure in server-status:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/server-status:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /server-status → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #10: Information Disclosure in debug:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/debug:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-215
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /debug → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #11: Information Disclosure in actuator:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/actuator:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /actuator → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #12: Information Disclosure in robots.txt:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 28 bytes
3 | Preview: User-agent: *
4 | Disallow: /ftp
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #13: Information Disclosure in sitemap.xml:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/sitemap.xml:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /sitemap.xml → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #14: Information Disclosure in .DS_Store:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/.DS_Store:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /.DS_Store → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #15: Missing Security Header in :0

Risk Score	0.3168
Affected Location	https://juice-shop.herokuapp.com/#!/0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation

One or more recommended HTTP security headers are missing from the server response. Security headers instruct the browser to enable built-in protections against common web attacks.

Code or HTTP Excerpt

```
1 | Response headers: Strict-Transport-Security = (not set)
```

Business Impact

Missing security headers leave the application and its users more vulnerable to XSS, clickjacking, and data injection attacks.

Fix Recommendation

Rule-based recommendation: Configure your web server or application to send the missing security headers. Key headers include: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options (nosniff), X-Frame-Options (DENY or SAMEORIGIN), and Referrer-Policy.

LLM recommendation: Configure your web server or application to send the missing security headers. Key headers include: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options (nosniff),

X-Frame-Options (DENY or SAMEORIGIN), and Referrer-Policy.

[LOW] #16: Information Disclosure in :0

Risk Score	0.2496
Affected Location	https://juice-shop.herokuapp.com/#!/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | Response headers: Referrer-Policy = (not set)
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

Appendix

Deduplication Statistics

Total raw findings: 18 | After deduplication: 16 | Reduction: 11%

Scan Metadata

Scan ID	dd1453f5-518a-4eb5-a7ec-156444c4faa1
Target	https://juice-shop.herokuapp.com/##
Timestamp	2026-05-08T03:07:14.956387+00:00
Duration	91.6s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "0f973c98-c4ef-48ac-90ce-96b844cd0906",
    "title": "Missing Auth in admin:0",
    "file": "https://juice-shop.herokuapp.com/admin",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "MISSING_AUTH",
    "description": "Admin panel may be accessible without proper authentication.",
    "rule_id": "sensitive-path-admin",
    "confidence": 0.85,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "GET /admin \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (
    \"sources\": [
      \"url-scanner\"
    ],
    \"risk_score\": 0.6839,
    \"risk_category\": \"HIGH\",
    \"category_source\": \"score\",
    \"category_reason\": \"score-threshold\",
    \"llm_explanation\": \"Missing or broken authentication allows unauthorized users to access protected functi
    \"fix_suggestion\": \"Ensure all sensitive endpoints require authentication. Use established authentication
    \"business_impact\": \"Unauthorized users could access sensitive data or perform privileged operations with
    \"raw\": {
      \"url\": \"https://juice-shop.herokuapp.com/admin\",
      \"status\": 200,
      \"path\": \"/admin\"
    }
  },
  {
    \"id\": \"a2359478-7da4-4f82-8acd-2a410055fffa\",
    \"title\": \"Information Disclosure in .env:0\",
    \"file\": \"https://juice-shop.herokuapp.com/.env\",
    \"line_start\": 0,
    \"line_end\": null,
    \"severity\": \"HIGH\",
    \"vuln_type\": \"INFORMATION_DISCLOSURE\",
```

```

    "description": "Exposed .env file \u2014 may contain secrets, API keys, and database credentials.",
    "rule_id": "sensitive-path-.env",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /.env \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (C
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5335,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
    "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
    "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific softwa
    "raw": {
        "url": "https://juice-shop.herokuapp.com/.env",
        "status": 200,
        "path": "/.env"
    }
},
{
    "id": "3c1d6988-dc5c-4dfa-ac7e-5dcf045ea555",
    "title": "Cors Misconfiguration in crossdomain.xml:0",
    "file": "https://juice-shop.herokuapp.com/crossdomain.xml",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "CORS_MISCONFIGURATION",
    "description": "crossdomain.xml found \u2014 may allow Flash-based cross-domain requests.",
    "rule_id": "sensitive-path-crossdomain.xml",
    "confidence": 0.85,
    "cwe_id": "CWE-942",
    "cvss_score": null,
    "code_snippet": "GET /crossdomain.xml \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (C
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.485,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server's Cross-Origin Resource Sharing (CORS) policy is overly permissive, potentially
    "fix_suggestion": "Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcards.
    "business_impact": "A malicious website could make authenticated API requests on behalf of your users and
    "raw": {
        "url": "https://juice-shop.herokuapp.com/crossdomain.xml",
        "status": 200,
        "path": "/crossdomain.xml"
    }
},
{
    "id": "c6d10201-a58e-47ff-98eb-af2a52510ed2",
    "title": "Information Disclosure in config:0",
    "file": "https://juice-shop.herokuapp.com/.git/config",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Exposed .git directory \u2014 source code and commit history are publicly accessible.",
    "rule_id": "sensitive-path-.git-config",
    "confidence": 0.85,
    "cwe_id": "CWE-538",
    "cvss_score": null,
    "code_snippet": "GET /.git/config \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (C
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.4462,
    "risk_category": "MEDIUM",

```

```

"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof",
"raw": {
  "url": "https://juice-shop.herokuapp.com/.git/config",
  "status": 200,
  "path": "/.git/config"
}
},
{
  "id": "6e9625e1-1309-4124-b2da-1ecfa76aa87a",
  "title": "Information Disclosure in backup.sql:0",
  "file": "https://juice-shop.herokuapp.com/backup.sql",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Database backup file is publicly accessible \u2014 critical data exposure.",
  "rule_id": "sensitive-path-backup.sql",
  "confidence": 0.85,
  "cwe_id": "CWE-530",
  "cvss_score": null,
  "code_snippet": "GET /backup.sql \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyr",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4462,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/backup.sql",
    "status": 200,
    "path": "/backup.sql"
  }
},
{
  "id": "0a74768e-455b-48d6-aba8-5a49fecf4cff",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/wp-admin/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "WordPress admin panel is publicly accessible.",
  "rule_id": "sensitive-path-wp-admin",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /wp-admin/ \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyr",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.422,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/wp-admin/",
    "status": 200,
    "path": "/wp-admin/"
  }
}
},

```

```

{
  "id": "ba9e6bad-80f6-4651-a6fe-1236a14aa5d2",
  "title": "Cors Misconfiguration in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "CORS_MISCONFIGURATION",
  "description": "CORS allows all origins (*). While credentials are not included, this may expose public",
  "rule_id": "cors-wildcard",
  "confidence": 0.6,
  "cwe_id": "CWE-942",
  "cvss_score": null,
  "code_snippet": "Access-Control-Allow-Origin: *",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3588,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server's Cross-Origin Resource Sharing (CORS) policy is overly permissive, poten",
  "fix_suggestion": "Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wi",
  "business_impact": "A malicious website could make authenticated API requests on behalf of your users an",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "acao": "*"
  }
},
{
  "id": "935ca23e-82c8-411c-bc3c-d8509eb65e80",
  "title": "Information Disclosure in phpinfo.php:0",
  "file": "https://juice-shop.herokuapp.com/phpinfo.php",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "PHP info page is publicly accessible \u2014 exposes server configuration details.",
  "rule_id": "sensitive-path-phpinfo.php",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /phpinfo.php \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copy",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/phpinfo.php",
    "status": 200,
    "path": "/phpinfo.php"
  }
},
{
  "id": "bd2f32b5-dd61-439e-b782-8c385d2b1820",
  "title": "Information Disclosure in server-status:0",
  "file": "https://juice-shop.herokuapp.com/server-status",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Apache server-status page is publicly accessible.",
  "rule_id": "sensitive-path-server-status",
  "confidence": 0.85,
  "cwe_id": "CWE-200",

```

```
"cvss_score": null,
"code_snippet": "GET /server-status \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Cop
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof
"raw": {
  "url": "https://juice-shop.herokuapp.com/server-status",
  "status": 200,
  "path": "/server-status"
}
},
{
  "id": "ac79204b-5197-4d6d-9d16-2c97d7eb058c",
  "title": "Information Disclosure in debug:0",
  "file": "https://juice-shop.herokuapp.com/debug",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Debug endpoint is publicly accessible \u2014 may expose sensitive application internals",
  "rule_id": "sensitive-path-debug",
  "confidence": 0.85,
  "cwe_id": "CWE-215",
  "cvss_score": null,
  "code_snippet": "GET /debug \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof
"raw": {
  "url": "https://juice-shop.herokuapp.com/debug",
  "status": 200,
  "path": "/debug"
}
},
{
  "id": "ea934bc3-af79-4771-b7de-76946b2e4505",
  "title": "Information Disclosure in actuator:0",
  "file": "https://juice-shop.herokuapp.com/actuator",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Spring Boot Actuator endpoints are publicly accessible.",
  "rule_id": "sensitive-path-actuator",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /actuator \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
```

```
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software",
"raw": {
  "url": "https://juice-shop.herokuapp.com/actuator",
  "status": 200,
  "path": "/actuator"
}
},
{
  "id": "1ff732d0-b9bc-47ec-9d84-f6c16ccd14b0",
  "title": "Information Disclosure in robots.txt:0",
  "file": "https://juice-shop.herokuapp.com/robots.txt",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "robots.txt may reveal hidden paths and sensitive directories.",
  "rule_id": "sensitive-path-robots.txt",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 28 bytes\nPreview: User-agent: *\nDisallow: /admin\n\n",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "MEDIUM",
  "category_source": "consistency_cache",
  "category_reason": "locked to historical category MEDIUM",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive paths.",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/robots.txt",
    "status": 200,
    "path": "/robots.txt"
  }
},
{
  "id": "e10634e8-a6fa-46bf-84d7-f06c4e182a7d",
  "title": "Information Disclosure in sitemap.xml:0",
  "file": "https://juice-shop.herokuapp.com/sitemap.xml",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "sitemap.xml may reveal internal URL structure.",
  "rule_id": "sensitive-path-sitemap.xml",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /sitemap.xml \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright 2019\n\n",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive paths.",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/sitemap.xml",
    "status": 200,
    "path": "/sitemap.xml"
  }
},
{
  "id": "89556a28-4ec9-4fbb-b154-e79ceb7b3bad",
  "title": "Information Disclosure in .DS_Store:0",
  "file": "https://juice-shop.herokuapp.com/.DS_Store",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": ".DS_Store file may reveal internal file structure.",
  "rule_id": "sensitive-path-ds-store",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /.DS_Store \u2192 HTTP 200\nContent-Length: 4096 bytes\nPreview: \n\n",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive paths.",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/.DS_Store",
    "status": 200,
    "path": "/.DS_Store"
  }
}
```

```

"line_start": 0,
"line_end": null,
"severity": "MEDIUM",
"vuln_type": "INFORMATION_DISCLOSURE",
"description": "macOS .DS_Store file is publicly accessible \u2014 may reveal directory structure.",
"rule_id": "sensitive-path-.DS_Store",
"confidence": 0.85,
"cwe_id": "CWE-538",
"cvss_score": null,
"code_snippet": "GET /.DS_Store \u2019 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof
"raw": {
  "url": "https://juice-shop.herokuapp.com/.DS_Store",
  "status": 200,
  "path": "/.DS_Store"
}
},
{
  "id": "ee3acee9-531c-4891-b92a-96eafe9aa552",
  "title": "Missing Security Header in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "MISSING_SECURITY_HEADER",
  "description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow
  "rule_id": "header-missing-strict-transport-security",
  "confidence": 0.95,
  "cwe_id": "CWE-319",
  "cvss_score": null,
  "code_snippet": "Response headers: Strict-Transport-Security = (not set)",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3168,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "One or more recommended HTTP security headers are missing from the server response.",
  "fix_suggestion": "Configure your web server or application to send the missing security headers. Key he
  "business_impact": "Missing security headers leave the application and its users more vulnerable to XSS,
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "header": "Strict-Transport-Security",
    "check": "missing_header"
  }
},
{
  "id": "1121ce3b-c686-4440-bc4f-e925ad70b996",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Missing Referrer-Policy header. Sensitive information in URLs may be leaked to third-par
  "rule_id": "header-missing-referrer-policy",
  "confidence": 0.8,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "Response headers: Referrer-Policy = (not set)",
  "sources": [

```

```
    "url-scanner"  
  ],  
  "risk_score": 0.2496,  
  "risk_category": "LOW",  
  "category_source": "score",  
  "category_reason": "score-threshold",  
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",  
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",  
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software",  
  "raw": {  
    "url": "https://juice-shop.herokuapp.com/#/",  
    "header": "Referrer-Policy",  
    "check": "missing_header"  
  }  
}  
]
```